

Software Requirements Specification

Table of Contents

1	Software Requirements Specification (SRS).....	3
1.1	TakeLow — Lowest Unique Bid Auction Platform	3
1.2	Document Control	3
1.2.1	Version History	4
1.2.2	Distribution List.....	4
1.2.3	Confidentiality Notice.....	5
1.3	Table of Contents	5
1.4	1. Introduction	6
1.4.1	1.1 Purpose	6
1.4.2	1.2 Scope	6
1.4.3	1.3 Definitions and Acronyms	6
1.4.4	1.4 References	7
1.4.5	1.5 Stakeholders	7
1.5	2. Overall Description.....	8
1.5.1	2.1 System Objectives	8
1.5.2	2.2 User Classes and Characteristics.....	8
1.5.3	2.3 Operating Environment	8
1.5.4	2.4 Design Constraints	9
1.5.5	2.5 Assumptions and Dependencies	9
1.6	3. Functional Requirements.....	9
1.6.1	3.1 User Registration and Authentication.....	9
1.6.2	3.2 Product and Auction Management.....	10
1.6.3	3.3 Bidding Engine	11
1.6.4	3.4 Winner Determination and Payment	12
1.6.5	3.5 Wallet Management.....	13
1.6.6	3.6 Notifications.....	13
1.6.7	3.7 Admin Operations.....	14
1.6.8	3.8 Favorites	16

1.6.9	3.9 Comprehensive Audit Logging	16
1.6.10	3.10 Redis High Availability	17
1.6.11	3.11 Backup and Disaster Recovery	17
1.6.12	3.12 WebSocket Horizontal Scaling.....	18
1.6.13	3.13 Performance & Caching	18
1.7	4. Non-Functional Requirements	18
1.7.1	4.1 Performance	18
1.7.2	4.2 Scalability	19
1.7.3	4.3 Availability.....	19
1.7.4	4.4 Security.....	20
1.7.5	4.5 Reliability	21
1.7.6	4.6 Maintainability.....	21
1.7.7	4.7 Usability.....	21
1.8	5. Interface Requirements	22
1.8.1	5.1 User Interfaces	22
1.8.2	5.2 External System Interfaces.....	22
1.8.3	5.3 Internal Service Interfaces.....	22
1.9	6. Data Requirements.....	23
1.9.1	6.1 Data Entities.....	23
1.9.2	6.2 Data Retention	23
1.9.3	6.3 Data Privacy	24
1.9.4	6.4 Backup and Recovery Data.....	24
1.10	7. Security Requirements.....	24
1.10.1	7.1 Authentication.....	24
1.10.2	7.2 Authorization.....	24
1.10.3	7.3 Input Validation	24
1.10.4	7.4 Cryptography.....	25
1.10.5	7.5 Audit and Monitoring.....	25
1.11	8. Compliance & Audit Requirements.....	25
1.11.1	8.1 Traceability.....	25
1.11.2	8.2 Financial Compliance	25
1.11.3	8.3 Data Protection	25
1.11.4	8.4 Disaster Recovery Compliance.....	26

1.12	9. Legal & Regulatory Compliance.....	26
1.12.1	9.1 Financial Regulations.....	26
1.12.2	9.2 Data Protection	27
1.12.3	9.3 Consumer Protection.....	27
1.12.4	9.4 Standards Conformance	28
1.13	10. Risk Assessment & Mitigation.....	28
1.13.1	10.1 Operational Risks	28
1.13.2	10.2 Financial Risks.....	29
1.13.3	10.3 Technical Risks.....	30
1.13.4	10.4 Security Risks	31
1.14	11. Business Rules Summary.....	32
1.15	12. Acceptance Criteria	34
1.15.1	12.1 Authentication & Registration	34
1.15.2	12.2 Product & Auction Management	34
1.15.3	12.3 Bidding Engine	35
1.15.4	12.4 Winner Determination & Payment.....	35
1.15.5	12.5 Admin Operations.....	35
1.15.6	12.6 Performance & Caching	36
1.15.7	12.7 Security	36
1.16	13. Traceability Matrix.....	36
1.17	14. Glossary	47

1 Software Requirements Specification (SRS)

1.1 TakeLow — Lowest Unique Bid Auction Platform

1.2 Document Control

Field	Value
Document Title	Software Requirements Specification — TakeLow Platform
Document Version	6.0
Document Date	2026-08-18

Field	Value
Document Status	Approved for Release
Compliance Standard	IEEE-830:1998
Classification	Confidential — Internal & Authorized External Review
Document Owner	TakeLow Engineering — Platform Architecture Team

1.2.1 Version History

Version	Date	Author	Reviewer	Approver	Summary of Changes
1.0	2026-01-15	Engineering Team	Tech Lead	CTO	Initial SRS draft
2.0	2026-03-10	Engineering Team	Architecture Review Board	CTO	Added wallet, payment gateway integrations
3.0	2026-05-02	Engineering Team	Security Working Group	CTO	Added security requirements, audit logging
4.0	2026-06-20	Engineering Team	Compliance Review Board	CTO	Added backup/DR, Redis HA, WebSocket scaling
5.0	2026-08-18	Engineering Team	Architecture Review Board	CTO	Added comprehensive audit, fine-grained permissions
6.0	2026-08-18	Platform Architecture Team	Architecture Review Board	CTO	Enterprise-grade: Prisma migration, T&C, product approval, settlement reports, analytics, audit viewer, winner management, Redis caching, legal/compliance, risk assessment, acceptance criteria, glossary

1.2.2 Distribution List

Recipient Role	Organization	Purpose
Chief Technology Officer	TakeLow	Executive approval

Recipient Role	Organization	Purpose
Architecture Review Board	TakeLow	and oversight Architectural conformance review
Security Working Group	TakeLow	Security requirements validation
Compliance Review Board	TakeLow	Regulatory and compliance verification
Engineering Team Lead	TakeLow	Implementation authority
Quality Assurance Lead	TakeLow	Test planning and acceptance
Product Management	TakeLow	Requirements traceability and scope
Operations / SRE Team	TakeLow	Deployment and operational readiness
Authorized External Assessor	Third-Party Audit Firm	Independent verification

1.2.3 Confidentiality Notice

This document is classified as **Confidential**. It contains proprietary information pertaining to the TakeLow platform architecture, security controls, and operational procedures. Unauthorized reproduction, distribution, or disclosure of this document, in whole or in part, is strictly prohibited. Recipients are bound by applicable confidentiality agreements. This document shall be stored and transmitted using approved secure channels only.

1.3 Table of Contents

1. Introduction
2. Overall Description
3. Functional Requirements
4. Non-Functional Requirements
5. Interface Requirements

6. Data Requirements
 7. Security Requirements
 8. Compliance & Audit Requirements
 9. Legal & Regulatory Compliance
 10. Risk Assessment & Mitigation
 11. Business Rules Summary
 12. Acceptance Criteria
 13. Traceability Matrix
 14. Glossary
-

1.4 1. Introduction

1.4.1 1.1 Purpose

This document specifies the functional and non-functional requirements for **TakeLow**, a mobile-first reverse auction platform operating on the **Lowest Unique Bid (LUB)** mechanism. It serves as the authoritative reference for developers, architects, testers, and stakeholders throughout the Software Development Lifecycle (SDLC).

This document is prepared in conformance with **IEEE Standard 830-1998** (*IEEE Recommended Practice for Software Requirements Specifications*). The structure, language conventions, and content organization adhere to the recommended practice. Mandatory requirements use the verb “**shall**”; recommended requirements use “**should**”; optional requirements use “**may**”.

1.4.2 1.2 Scope

TakeLow enables users to participate in timed auctions by placing monetary bids. The winner is the participant who submits the **lowest unique bid amount** (up to 2 decimal places) before the auction timer expires. Winners shall pay the winning amount within a configurable deadline (default 24 hours).

The system encompasses: - **Three microservices**: Identity Service, Auction Engine, Query Service - **Two frontend applications**: Web (React + Vite) and Mobile (React Native / Expo) - **PostgreSQL 15 / Citus** distributed database with **Redis 7** for caching, rate-limiting, and real-time messaging - **Prisma ORM** for type-safe database access and migration management - **Payment gateway integrations**: SikinaPay and Awash Bank - **Push notification infrastructure**: Expo Push Service + SMS

1.4.3 1.3 Definitions and Acronyms

Refer to [Section 14 — Glossary](#) for the complete and expanded definitions table.

1.4.4 1.4 References

Reference	Description
README.md	Project overview and quick-start guide
SRS.md (prior version)	Previous version of this document (v5.0)
SECURITY.md	OWASP-aligned security architecture
AGENTS.md	Developer agent instructions and conventions
database/migrations/ k8s/ BRD.md	Schema evolution history (raw SQL, idempotent) Production Kubernetes manifests Business Requirements Document (source of business rules)
IEEE Std 830-1998	IEEE Recommended Practice for Software Requirements Specifications
ISO/IEC 27001:2022	Information security management systems
OWASP Top 10 (2021)	Web application security risks reference

1.4.5 1.5 Stakeholders

Stakeholder	Interest in System	Key Concerns
End Users (Bidders)	Participate in auctions, win and pay	Fairness, transparency, ease of use, payment reliability
Administrators	Operate and oversee the platform	Control, visibility, auditability, reporting
Engineering Team	Implement and maintain the system	Clarity, traceability, testability, maintainability
Security Working Group	Ensure system security	Threat mitigation, data protection, access control
Compliance Review Board	Verify regulatory adherence	Financial compliance, data protection, audit trails
Operations / SRE Team	Run the platform in production	Availability, scalability, recoverability, monitoring
Payment Partners	Process financial transactions	Integration correctness, signature validation, reconciliation
Executive Leadership	Business viability	Revenue, risk, reputation, operational continuity

1.5 2. Overall Description

1.5.1 2.1 System Objectives

1. The system shall provide a fair, transparent, and auditable reverse auction platform.
2. The system shall support high concurrency bidding with real-time updates.
3. The system shall enable secure wallet-based and gateway-based payments.
4. The system shall maintain comprehensive audit trails for compliance.
5. The system shall scale horizontally via Citus distributed PostgreSQL and read replicas.
6. The system shall achieve sub-100ms response times for read operations.
7. The system shall protect user funds and data through defense-in-depth security controls.
8. The system shall provide administrative tooling for full operational oversight and reporting.

1.5.2 2.2 User Classes and Characteristics

User Class	Description	Key Capabilities
Guest	Unauthenticated visitor	Browse products and auctions, view closed auctions
Registered User	Authenticated via phone/email/oauth	Place bids, manage wallet, view results, favorites, notifications
Admin	Elevated privileges	Full CRUD on auctions/products, user management, stats, audit logs, monitor live auctions, settlement reports, analytics, winner management
System	Automated processes	Cron jobs, BullMQ workers, webhook receivers, notification dispatchers, reconciliation jobs

1.5.3 2.3 Operating Environment

- **Backend:** Node.js 20, NestJS framework
- **Frontend:** React 19 + TypeScript + Vite + Tailwind CSS
- **Mobile:** React Native 0.86 + Expo
- **Database:** PostgreSQL 15 + Citus 12.1 (distributed)
- **ORM:** Prisma (type-safe client, migration management)
- **Cache/Queue:** Redis 7 (BullMQ, rate limiting, session storage, WebSocket adapter, Pub/Sub, read caching)
- **Deployment:** Docker Compose (development), Kubernetes (production)

1.5.4 2.4 Design Constraints

- All database schema changes shall be via versioned migrations (no ORM auto-sync).
- JWT secrets shall be identical across all three services.
- Bid amounts shall be encrypted at rest for closed auctions.
- Webhook signatures shall be validated with constant-time comparison.
- 5xx error details shall be masked from clients; raw errors shall be logged server-side.
- All admin actions, security events, and business operations shall be logged to an immutable audit trail.
- Backup and disaster recovery procedures shall be tested quarterly.
- All monetary calculations shall use integer-based arithmetic (minor units) to avoid floating-point errors.

1.5.5 2.5 Assumptions and Dependencies

- Payment gateways (SikinaPay, Awash Bank) shall be available and reachable during auction operations.
- SMS provider (smsethiopia.com) API shall be accessible for critical notifications.
- Expo Push Service shall be reachable for mobile notifications.
- Citus coordinator node shall be available in production for distributed queries.
- Network time protocol (NTP) shall be synchronized across all service instances for nonce validation.
- Payment gateway APIs shall conform to their documented interface specifications.

1.6 3. Functional Requirements

Priority Convention: Each functional requirement is assigned a priority: - **Must** — Mandatory for release; absence blocks acceptance. - **Should** — Highly desirable; absence is a non-blocking defect. - **Could** — Optional enhancement; implemented if resources permit.

1.6.1 3.1 User Registration and Authentication

Req ID	Priority	Requirement
FR-AUTH-01	Must	The system shall allow user registration via phone number, email, TeleBirr OAuth, Banking API OAuth, or Super-App OAuth.
FR-AUTH-02	Must	The system shall hash passwords using bcrypt with cost factor 12.
FR-AUTH-03	Must	The system shall issue JWT access tokens (15-minute expiry) and refresh tokens (7-day expiry, rotated

Req ID	Priority	Requirement
		on each refresh).
FR-AUTH-04	Must	The system shall store refresh tokens as bcrypt hashes in the database.
FR-AUTH-05	Must	The system shall enforce a login rate limit of 5 attempts per 60 seconds per identifier via Redis.
FR-AUTH-06	Should	The system shall auto-refresh access tokens 60 seconds before expiry and retry failed requests with the new token.
FR-AUTH-07	Must	The system shall invalidate all sessions when a user is banned.
FR-AUTH-08	Must	The system shall support wallet PIN setup with 4-6 digit numeric codes, hashed with bcrypt cost 10.
FR-AUTH-09	Must	The system shall lock wallet PIN for 30 minutes after 5 failed attempts.

1.6.2 3.2 Product and Auction Management

Req ID	Priority	Requirement
FR-PROD-01	Must	The system shall allow admins to create, read, update, and delete products with name, description, images, market price, brand, category, and specifications.
FR-PROD-02	Must	The system shall implement a product approval workflow with states PENDING → APPROVED → REJECTED. Only APPROVED products shall be eligible for auction creation. The system shall record the approving/rejecting admin, timestamp, and optional rejection reason in the audit trail.
FR-AUCT-01	Must	The system shall allow admins to create auctions linked to products with configurable start/end times, min bid, max bid, bid fee, and number of winners.

Req ID	Priority	Requirement
FR-AUCT-02	Must	The system shall assign a unique 5-character public code to each auction.
FR-AUCT-03	Must	The system shall display active auctions to all users and closed/expired auctions with winner information.
FR-AUCT-04	Should	The system shall extend auction duration by 24 hours if minimum bid threshold is not met (fair-play extension).
FR-AUCT-05	Should	The system shall extend auction duration by 24 hours if no unique bids exist (maximum unlimited extensions).
FR-AUCT-06	Must	The system shall close auctions immediately when the maximum bid count is reached.
FR-AUCT-07	Must	Admins shall be able to force-close auctions (no winner declared).

1.6.3 3.3 Bidding Engine

Req ID	Priority	Requirement
FR-BID-01	Must	The system shall require users to pay a non-refundable bid service fee before placing bids.
FR-BID-02	Must	The system shall enforce a maximum of 150 bids per user per auction.
FR-BID-03	Must	The system shall generate a unique ticket number (BID_ + 12 hex chars) for each bid.
FR-BID-04	Must	The system shall track bid frequencies using Redis ZSETs to determine the lowest unique bid.
FR-BID-05	Should	The system shall detect and notify users when their previously unique bid amount becomes duplicated.
FR-BID-06	Must	The system shall encrypt bid

Req ID	Priority	Requirement
		amounts using AES-256-GCM before storage for closed auctions.
FR-BID-07	Must	The system shall prevent duplicate bid submissions via nonce validation (Redis-backed, 60s TTL).
FR-BID-08	Must	The system shall enforce bidding window validation server-side (auction must be active).
FR-BID-09	Should	The system shall batch-persist bids using BullMQ (batch size 50) for performance.
FR-BID-10	Must	The system shall broadcast real-time bid count updates via Socket.io.
FR-TC-01	Must	The system shall require users to accept the active Terms & Conditions before placing their first bid in any auction. The system shall record the T&C version, acceptance timestamp, and user ID. Users who have not accepted the current T&C version shall be prevented from bidding.

1.6.4 3.4 Winner Determination and Payment

Req ID	Priority	Requirement
FR-WIN-01	Must	The system shall calculate winners using the lowest unique bid algorithm upon auction closure.
FR-WIN-02	Must	The system shall support multiple winners per auction (configurable num_winners).
FR-WIN-03	Must	The system shall assign a rank to each winner based on bid amount (lowest first).
FR-WIN-04	Must	The system shall send winner notifications via push, SMS, and in-app inbox.
FR-WIN-05	Must	The system shall require winners to pay within 24 hours (configurable

Req ID	Priority	Requirement
FR-WIN-06	Must	deadline). The system shall rotate to the next unpaid winner if the deadline expires.
FR-WIN-07	Must	The system shall support payment via SikinaPay, Awash Bank, or internal wallet.
FR-WIN-08	Must	The system shall reconcile pending payments every 30 minutes via cron job.
FR-WIN-09	Must	The system shall expire payments after 30 seconds of inactivity.
FR-WIN-10	Must	The system shall send payment reminder notifications to winners with pending payments via both SMS and push notification channels. Reminders shall be sent at configurable intervals (default: 6 hours and 1 hour before deadline expiry). The system shall log each reminder dispatch to the audit trail.

1.6.5 3.5 Wallet Management

Req ID	Priority	Requirement
FR-WAL-01	Must	The system shall maintain an internal wallet with deposit, balance inquiry, and transaction history.
FR-WAL-02	Must	The system shall deduct bid fees atomically with pessimistic write locking.
FR-WAL-03	Must	The system shall support wallet refunds for expired auction payments.
FR-WAL-04	Must	The system shall process external deposits via fintech webhook with HMAC-SHA256 signature verification.

1.6.6 3.6 Notifications

Req ID	Priority	Requirement
--------	----------	-------------

Req ID	Priority	Requirement
FR-NOT-01	Must	The system shall send in-app notifications for bid confirmations, outbid alerts, winner announcements, auction extensions, and forced closures.
FR-NOT-02	Should	The system shall send push notifications via Expo Push Service for mobile users.
FR-NOT-03	Should	The system shall send SMS notifications via smsethiopia.com for critical events.
FR-NOT-04	Must	The system shall allow users to view, mark read, and bulk-mark-read notifications.

1.6.7 3.7 Admin Operations

Req ID	Priority	Requirement
FR-ADM-01	Must	The system shall provide an admin dashboard with platform statistics (users, auctions, bids, revenue, trends).
FR-ADM-02	Must	The system shall allow admins to manage users (list, search, role assignment, ban/unban, bulk operations).
FR-ADM-03	Must	The system shall support fine-grained permissions (users:read, users:role, users:ban, auctions:write, etc.).
FR-ADM-04	Must	The system shall allow admins to draw winners manually for closed auctions.
FR-ADM-05	Must	The system shall allow admins to monitor live auctions with real-time bid tables.
FR-ADM-06	Must	The system shall log all admin actions to an immutable audit trail.
FR-ADM-07	Must	The system shall support CSV export for users, transactions, auctions, and products.

Req ID	Priority	Requirement
FR-ADM-08	Must	The system shall generate settlement reports containing total revenue, platform share, tax withheld, and commission per auction and per settlement period. Reports shall be exportable in CSV and PDF formats. The system shall record report generation in the audit trail.
FR-ADM-09	Must	The system shall provide an advanced analytics dashboard with revenue analytics (trends, growth, forecasts), user analytics (registration, activity, retention), auction analytics (participation, closure rates, extension frequency), bid analytics (volume, distribution, success rates), and payment analytics (success rates, gateway performance, failure analysis). All analytics shall support configurable date ranges and granularity.
FR-ADM-10	Must	The system shall provide an audit log viewer with filtering by actor, action, entity type, entity ID, and date range. The viewer shall support pagination, sorting, and CSV export of filtered results. Access to the audit log viewer shall require the <code>audit:read</code> permission.
FR-ADM-11	Must	The system shall provide a winner management dashboard allowing admins to view all winners, filter by status (pending payment, paid, expired, rotated), manually confirm payments, extend payment deadlines, and trigger winner rotation. All actions shall be logged to the audit trail.

1.6.8 3.8 Favorites

Req ID	Priority	Requirement
FR-FAV-01	Should	The system shall allow users to add/remove auctions from favorites.
FR-FAV-02	Should	The system shall display a watchlist of favorite auctions.

1.6.9 3.9 Comprehensive Audit Logging

Req ID	Priority	Requirement
FR-AUD-01	Must	The system shall log all admin actions (user management, auction/product CRUD, role changes, bans, permission grants/revokes) to an immutable audit trail with actor ID, action, entity type, entity ID, and details.
FR-AUD-02	Must	The system shall log all bidding events (bid placement, duplicate detection, max bid reached, auction closure, winner determination, extensions, force closures) with user ID, auction ID, amounts, and outcomes.
FR-AUD-03	Must	The system shall log all payment events (payment link creation, confirmation, wallet payments, bid fee payments, webhook receipts, reconciliation) with transaction ID, amount, gateway, and status.
FR-AUD-04	Must	The system shall log user access to sensitive data (auction views, bid history, win history, other user data) with actor ID, target entity, and access type.
FR-AUD-05	Must	The system shall provide audit log query APIs with filtering by actor, action, entity type, entity ID, and date range.
FR-AUD-06	Must	The system shall store audit logs in a dedicated table with indexes on actor_id, action, entity_type, and

Req ID	Priority	Requirement
--------	----------	-------------

created_at for efficient querying.

1.6.10 3.10 Redis High Availability

Req ID	Priority	Requirement
--------	----------	-------------

FR-REDIS-01	Should	The system shall support Redis Sentinel for automatic master failover with configurable quorum.
FR-REDIS-02	Should	The system shall support Redis Cluster mode for horizontal scaling and sharding.
FR-REDIS-03	Should	The system shall automatically detect and use Sentinel or Cluster configuration via environment variables.
FR-REDIS-04	Must	The system shall maintain backward compatibility with standalone Redis for development.

1.6.11 3.11 Backup and Disaster Recovery

Req ID	Priority	Requirement
--------	----------	-------------

FR-BACKUP-01	Must	The system shall support automated PostgreSQL backups via pgBackRest with full, differential, and incremental backup types.
FR-BACKUP-02	Should	The system shall support cloud-based backups via WAL-G with S3-compatible storage.
FR-BACKUP-03	Must	The system shall provide point-in-time recovery (PITR) using WAL archiving.
FR-BACKUP-04	Must	The system shall define RTO < 4 hours and RPO < 24 hours for disaster recovery.
FR-BACKUP-05	Must	The system shall provide automated restore scripts for both pgBackRest and WAL-G.
FR-BACKUP-06	Must	The system shall schedule daily full backups and 6-hour differential backups via Kubernetes CronJobs.

1.6.12 3.12 WebSocket Horizontal Scaling

Req ID	Priority	Requirement
FR-WS-01	Must	The system shall use Socket.io Redis adapter to broadcast WebSocket events across multiple auction-engine instances.
FR-WS-02	Must	The system shall maintain session affinity via Redis pub/sub for real-time auction updates.
FR-WS-03	Should	The system shall support connection scaling with zero code changes when adding auction-engine replicas.

1.6.13 3.13 Performance & Caching

Req ID	Priority	Requirement
FR-PERF-01	Must	The system shall implement a Redis caching layer for read-heavy endpoints including auction listings, product details, user profiles, and dashboard statistics. The system shall use configurable cache TTLs per endpoint class, support cache invalidation on write operations, and implement cache-aside pattern with graceful fallback to database on cache miss.

1.7 4. Non-Functional Requirements

1.7.1 4.1 Performance

Req ID	Priority	Requirement
NFR-PERF-01	Must	Read API responses shall complete within 100ms at p95 under normal load.
NFR-PERF-02	Must	The system shall support 10,000 concurrent active auctions.
NFR-PERF-03	Must	Bid placement shall complete within 200ms at p95.
NFR-PERF-04	Must	The system shall handle 1,000 bids

Req ID	Priority	Requirement
		per second per auction using Redis ZSETs and BullMQ batch persistence.
NFR-PERF-05	Must	WebSocket auction updates shall be delivered within 50ms.
NFR-PERF-06	Must	Database queries shall use indexes for all filter and sort operations (no full-table scans).

1.7.2 4.2 Scalability

Req ID	Priority	Requirement
NFR-SCALE-01	Must	The system shall scale horizontally by adding Citus worker nodes.
NFR-SCALE-02	Should	The query service shall support read replicas via READ_REPLICA_URL.
NFR-SCALE-03	Should	The system shall support Horizontal Pod Autoscaling (HPA) in Kubernetes.
NFR-SCALE-04	Should	Redis shall be clusterable for session storage and rate limiting at scale.
NFR-SCALE-05	Must	The auction engine shall scale WebSocket connections via Socket.io Redis adapter across multiple replicas.
NFR-SCALE-06	Should	Redis Sentinel shall provide automatic failover with < 30 second detection time.
NFR-SCALE-07	Should	Redis Cluster shall support horizontal sharding for session and cache data.

1.7.3 4.3 Availability

Req ID	Priority	Requirement
NFR-AVAIL-01	Must	The system shall target 99.9% uptime for backend services.
NFR-AVAIL-02	Must	Health endpoints shall return HTTP 503 when dependencies (DB/Redis) are degraded.

Req ID	Priority	Requirement
NFR-AVAIL-03	Must	Kubernetes liveness and readiness probes shall be configured for all services.
NFR-AVAIL-04	Must	Database backup and restore procedures shall be tested quarterly.
NFR-AVAIL-05	Must	Point-in-time recovery (PITR) shall be verified monthly.
NFR-AVAIL-06	Must	Redis Sentinel/Cluster failover shall be tested in staging before production deployment.

1.7.4 4.4 Security

Req ID	Priority	Requirement
NFR-SEC-01	Must	All HTTP traffic shall be protected via CORS with configurable allowed origins.
NFR-SEC-02	Must	JWT secrets shall be validated on startup and reject well-known defaults.
NFR-SEC-03	Must	Webhook payloads shall be verified with HMAC-SHA256 and timing-safe comparison.
NFR-SEC-04	Must	Bid nonces shall prevent replay attacks with 30-second clock skew tolerance.
NFR-SEC-05	Must	Internal service communication shall use API key authentication with constant-time comparison.
NFR-SEC-06	Must	Sensitive fields (passwords, PINs, refresh tokens) shall be hashed before storage.
NFR-SEC-07	Must	Error responses to clients shall mask 5xx details; raw errors shall be logged server-side.
NFR-SEC-08	Must	All audit logs shall be immutable once written; no UPDATE/DELETE operations allowed on audit_logs table.

Req ID	Priority	Requirement
NFR-SEC-09	Must	Redis Sentinel/Cluster connections shall use authentication and TLS in production.
NFR-SEC-10	Must	Backup data at rest shall be encrypted (S3 SSE-KMS or equivalent).

1.7.5 4.5 Reliability

Req ID	Priority	Requirement
NFR-REL-01	Must	Database migrations shall be idempotent and re-runnable.
NFR-REL-02	Must	The system shall recover gracefully from payment gateway failures with retry logic.
NFR-REL-03	Must	BullMQ workers shall retry failed jobs with exponential backoff (3 attempts).
NFR-REL-04	Must	The system shall maintain referential integrity via foreign key constraints and CASCADE rules.

1.7.6 4.6 Maintainability

Req ID	Priority	Requirement
NFR-MAIN-01	Must	All code shall be typed with TypeScript strict mode.
NFR-MAIN-02	Must	Database schema changes shall require explicit migrations (no auto-sync).
NFR-MAIN-03	Must	Code shall follow NestJS conventions with module-based architecture.
NFR-MAIN-04	Must	Frontend shall use component-based architecture with shared hooks and context.

1.7.7 4.7 Usability

Req ID	Priority	Requirement
NFR-USAB-01	Should	The mobile app shall support offline viewing of cached auctions and

Req ID	Priority	Requirement
		bids.
NFR-USAB-02	Must	The web app shall be responsive for desktop and mobile viewports.
NFR-USAB-03	Must	Payment flows shall provide clear status indicators and retry options.

1.8 5. Interface Requirements

1.8.1 5.1 User Interfaces

- **Web Application:** Responsive React SPA served via Nginx (production) or Vite dev server (development).
- **Mobile Application:** React Native app via Expo, supporting iOS and Android.
- **Admin Dashboard:** Integrated into web app with role-gated navigation, including analytics dashboard, settlement reports, audit log viewer, and winner management.

1.8.2 5.2 External System Interfaces

System	Protocol	Purpose	Integration Pattern
SikinaPay	HTTPS REST + Webhooks	Payment link generation, status checks, event notifications	Synchronous API + asynchronous webhook
Awash Bank	HTTPS REST + Webhooks	Payment link generation, status checks, event notifications	Synchronous API + asynchronous webhook
SMS Ethiopia	HTTPS REST	SMS bid confirmations and payment reminders	Synchronous API
Expo Push	HTTPS REST	Mobile push notifications	Synchronous API
TeleBirr	OAuth 2.0	Social login	OAuth authorization code flow
Banking API	OAuth 2.0	Social login	OAuth authorization code flow

1.8.3 5.3 Internal Service Interfaces

Service	Protocol	Communication Pattern
---------	----------	-----------------------

Service	Protocol	Communication Pattern
Identity → Auction Engine	HTTP REST (Internal API Key)	Synchronous (notifications, audit)
Identity → Query Service	HTTP REST (Internal API Key)	Synchronous (user resolution)
Auction Engine → Identity	HTTP REST (JWT)	Synchronous (user validation)
All Services → Redis	Redis Protocol	Synchronous (caching, rate limiting, locks, pub/sub)
All Services → PostgreSQL	PostgreSQL Protocol (via Prisma)	Synchronous (queries, transactions)
All Services → Audit Service	HTTP REST (Internal API Key)	Synchronous (audit logging)

1.9 6. Data Requirements

1.9.1 6.1 Data Entities

Entity	Description	Volume Estimate
Users	Registered platform users	100K+
Products	Auctioned items (with approval workflow state)	10K+
Auctions	Active or historical auctions	50K+
Bids	Individual bid submissions	10M+
Winners	Auction winner records	50K+
Payment Transactions	Payment gateway records	100K+
Favorites	User saved auctions	500K+
Notification Logs	In-app notification history	5M+
Audit Logs	Admin and security events	2M+
User Permissions	Fine-grained access control	500K+
T&C Acceptances	Terms & Conditions acceptance records	100K+
Settlement Reports	Revenue/settlement report records	10K+
Payment Reminders	Reminder dispatch records	100K+

1.9.2 6.2 Data Retention

- Bids: Retained indefinitely for audit and transparency.
- Payment transactions: Retained for 7 years (financial compliance).
- Notification logs: Retained for 1 year.

- Audit logs: Retained indefinitely.
- OTPs: Expired and deleted after 24 hours.
- T&C acceptance records: Retained indefinitely for legal evidence.
- Settlement reports: Retained for 7 years (financial compliance).
- Payment reminder records: Retained for 1 year.
- Database backups: Retained 30 days (daily full) + WAL archives for PITR.
- Redis snapshots: Retained 7 days.

1.9.3 6.3 Data Privacy

- Passwords hashed with bcrypt (cost 12).
- Refresh tokens hashed with bcrypt before storage.
- Wallet PINs hashed with bcrypt (cost 10).
- Bid amounts encrypted at rest (AES-256-GCM) for closed auctions.
- Phone numbers partially masked in logs.
- Backup data encrypted at rest (S3 SSE-KMS).
- Personal data access logged per FR-AUD-04.

1.9.4 6.4 Backup and Recovery Data

- pgBackRest repository: /var/lib/pgbackrest (PVC in Kubernetes).
- WAL-G S3 prefix: s3://take1ow-backups/postgres.
- Redis RDB snapshots: Every 6 hours to persistent volume + object storage.
- Kubernetes etcd snapshots: Daily to object storage.

1.10 7. Security Requirements

1.10.1 7.1 Authentication

- JWT-based stateless authentication with 15-minute access tokens.
- Refresh token rotation with bcrypt-hashed storage.
- Multi-strategy login: local phone/email, TeleBirr, Banking API, Super-App.

1.10.2 7.2 Authorization

- Role-based access control (user, admin).
- Fine-grained permission system (13+ distinct permissions).
- Admin endpoints protected by `@Roles('admin')` and `@Permissions(...)`.

1.10.3 7.3 Input Validation

- All external inputs validated via class-validator DTOs.
- SQL injection prevented via parameterized queries (Prisma).

- SSRF protection on image downloads (HTTPS only, private IP blocked, MIME validation).
- Rate limiting on login (5/min), bidding (10/s), OTP (3/min).

1.10.4 7.4 Cryptography

- HMAC-SHA256 for webhook signatures.
- AES-256-GCM for bid amount encryption.
- bcrypt for password and PIN hashing.
- Constant-time comparison for internal API keys and webhook signatures.

1.10.5 7.5 Audit and Monitoring

- Immutable audit logs for all admin actions and security events.
- Failed login attempt logging with actor identification.
- Real-time notification of security-relevant events.

1.11 8. Compliance & Audit Requirements

1.11.1 8.1 Traceability

All requirements shall be traceable to: - Design documents (SDD). - Implementation (source code). - Test cases. - Deployment configurations.

Refer to [Section 13 — Traceability Matrix](#) for the complete mapping.

1.11.2 8.2 Financial Compliance

- Payment records retained for 7 years.
- All payment state transitions logged with timestamps.
- Webhook signatures validated for non-repudiation.
- Reconcile cron jobs maintain payment consistency.
- All payment events logged to audit trail with actor, transaction ID, amount, gateway, and status.
- Settlement reports accurately reflect revenue, platform share, tax, and commission.

1.11.3 8.3 Data Protection

- Sensitive credentials never committed to version control.
- Environment variables used for all secrets.
- .env files gitignored.
- Production secrets injected via Kubernetes Secrets.
- Backup data encrypted at rest (S3 SSE-KMS or equivalent).
- Audit logs immutable once written (no UPDATE/DELETE).

1.11.4 8.4 Disaster Recovery Compliance

- RTO < 4 hours for full system recovery.
- RPO < 24 hours for database (daily backups + WAL archiving).
- PITR RTO < 1 hour for data corruption.
- Quarterly DR testing and documentation.
- Automated restore scripts for pgBackRest and WAL-G.

1.12 9. Legal & Regulatory Compliance

1.12.1 9.1 Financial Regulations

The system shall comply with applicable financial regulations governing digital payment processing and online auction operations:

Requirement	Description	Related FRs/NFRs
Transaction Record Retention	All financial transaction records shall be retained for a minimum of 7 years.	FR-AUD-03, §6.2, §8.2
Payment Reconciliation	The system shall reconcile all payment states at regular intervals to ensure financial consistency.	FR-WIN-08
Non-Repudiation	Webhook signatures and audit logs shall provide cryptographic non-repudiation for all payment events.	NFR-SEC-03, FR-AUD-03
Settlement Reporting	The system shall produce settlement reports detailing revenue, platform share, tax, and commission.	FR-ADM-08
Anti-Fraud Controls	The system shall implement rate limiting, nonce validation, and audit logging to detect and prevent fraudulent activity.	FR-BID-07, FR-AUTH-05, FR-AUD-02

1.12.2 9.2 Data Protection

The system shall protect personal data in accordance with recognized data protection principles:

Requirement	Description	Related FRs/NFRs
Data Minimization	The system shall collect only data necessary for platform operation.	§6.1
Encryption at Rest	Sensitive data (bid amounts, backups) shall be encrypted at rest.	FR-BID-06, NFR-SEC-10
Encryption in Transit	All inter-service and external communication shall use TLS.	NFR-SEC-01, NFR-SEC-09
Access Control	Access to personal data shall be restricted by role and permission.	§7.2, FR-ADM-03
Access Logging	All access to sensitive personal data shall be logged.	FR-AUD-04
Right to Erasure	The system should support user account deletion with associated data handling per applicable law.	—
Breach Notification	Security incidents involving personal data shall be documented and notified per applicable legal requirements.	§7.5

1.12.3 9.3 Consumer Protection

The system shall incorporate consumer protection measures:

Requirement	Description	Related FRs/NFRs
Terms & Conditions	Users shall accept applicable Terms & Conditions before participating in auctions.	FR-TC-01
Transparent Auction	Auction rules (LUB	§1.2, FR-AUCT-03

Requirement	Description	Related FRs/NFRs
Rules	mechanism, extensions, payment deadlines) shall be clearly communicated to users.	
Fair Play Extension	Auctions shall be extended if minimum participation thresholds are not met, ensuring fairness.	FR-AUCT-04, FR-AUCT-05
Payment Deadline Disclosure	Winners shall be clearly notified of payment deadlines and consequences of non-payment.	FR-WIN-04, FR-WIN-10
Non-Refundable Fee Disclosure	Bid service fees shall be clearly disclosed as non-refundable before payment.	FR-BID-01
Dispute Resolution	The system shall maintain comprehensive audit trails to support dispute resolution.	FR-AUD-01 through FR-AUD-06

1.12.4 9.4 Standards Conformance

Standard	Conformance Area
IEEE 830-1998	Software Requirements Specification format and content
ISO/IEC 27001:2022	Information security management (controls alignment)
OWASP Top 10 (2021)	Web application security risk mitigation
NIST SP 800-53	Security controls reference (where applicable)

1.13 10. Risk Assessment & Mitigation

1.13.1 10.1 Operational Risks

Risk ID	Risk Description	Likelihood	Impact	Mitigation
OR-01	Payment gateway downtime during active auction	Medium	High	Multi-gateway support (FR-WIN-07), retry logic (NFR-REL-

Risk ID	Risk Description	Likelihood	Impact	Mitigation
OR-02	SMS/Push notification delivery failure	Medium	Medium	02), reconciliation cron (FR-WIN-08) Multi-channel notifications (FR-WIN-04), delivery logging, retry via BullMQ (NFR-REL-03)
OR-03	Redis failover during active bidding	Low	High	Sentinel/Cluster HA (FR-REDIS-01/02), <30s failover (NFR-SCALE-06), staging testing (NFR-AVAIL-06)
OR-04	Database connection pool exhaustion under load	Medium	High	Connection pooling, Citus horizontal scaling (NFR-SCALE-01), read replicas (NFR-SCALE-02), Redis caching (FR-PERF-01)
OR-05	Winner disputes over auction fairness	Low	High	Immutable audit trail (FR-AUD-02), encrypted bid storage (FR-BID-06), transparent LUB algorithm (FR-WIN-01)

1.13.2

10.2 Financial Risks

Risk ID	Risk Description	Likelihood	Impact	Mitigation
FR-01	Payment reconciliation discrepancies	Low	High	30-minute reconciliation cron (FR-WIN-08), webhook

Risk ID	Risk Description	Likelihood	Impact	Mitigation
				signature validation (NFR-SEC-03), settlement reports (FR-ADM-08)
FR-02	Fraudulent chargebacks or disputed payments	Medium	Medium	Non-repudiation via audit logs (FR-AUD-03), HMAC webhook verification (NFR-SEC-03), transaction retention (§6.2)
FR-03	Wallet balance corruption from concurrent operations	Low	High	Pessimistic write locking (FR-WAL-02), atomic transactions, referential integrity (NFR-REL-04)
FR-04	Revenue misreporting	Low	Medium	Settlement reports with audit trail (FR-ADM-08), financial compliance logging (§8.2)

1.13.3 10.3 Technical Risks

Risk ID	Risk Description	Likelihood	Impact	Mitigation
TR-01	Data loss from database failure	Low	Critical	Automated backups (FR-BACKUP-01/02), PITR (FR-BACKUP-03), RPO < 24h (FR-BACKUP-04)
TR-02	Prolonged system outage	Low	Critical	99.9% uptime target (NFR-AVAIL-01),

Risk ID	Risk Description	Likelihood	Impact	Mitigation
TR-03	Migration failure during deployment	Medium	High	health probes (NFR-AVAIL-03), RTO < 4h (FR-BACKUP-04) Idempotent migrations (NFR-REL-01), rollback procedures, staging validation
TR-04	WebSocket connection drops at scale	Medium	Medium	Socket.io Redis adapter (FR-WS-01), reconnection logic, pub/sub affinity (FR-WS-02)
TR-05	Cache stampede on cache expiry	Low	Medium	Cache-aside with graceful fallback (FR-PERF-01), staggered TTLs

1.13.4 10.4 Security Risks

Risk ID	Risk Description	Likelihood	Impact	Mitigation
SR-01	Unauthorized access to admin functions	Low	Critical	Fine-grained permissions (FR-ADM-03), role-based access (§7.2), audit logging (FR-AUD-01)
SR-02	Replay attacks on bid submissions	Medium	High	Nonce validation with TTL (FR-BID-07), clock skew tolerance (NFR-SEC-04)
SR-03	SQL injection via user input	Low	Critical	Parameterized queries via Prisma (§7.3),

Risk ID	Risk Description	Likelihood	Impact	Mitigation
SR-04	SSRF via image upload URLs	Low	High	input validation DTOs HTTPS-only, private IP blocking, MIME validation (§7.3)
SR-05	JWT secret compromise	Low	Critical	Startup validation rejecting defaults (NFR- SEC-02), Kubernetes Secrets, rotation procedures
SR-06	Audit log tampering	Low	Critical	Immutable audit logs (NFR-SEC- 08), no UPDATE/DELETE on audit table
SR-07	Sensitive data exposure in backups	Low	High	Backup encryption at rest (NFR-SEC- 10), S3 SSE-KMS

1.14 11. Business Rules Summary

The following business rules are consolidated from the Business Requirements Document (BRD) and trace to functional requirements in [Section 3](#).

Rule ID	Business Rule	Related FRs
BR-01	The winner of an auction is the participant who submitted the lowest unique bid amount.	FR-WIN-01, FR-BID-04
BR-02	A bid is unique if no other participant submitted the same bid amount in the same auction.	FR-BID-04, FR-WIN-01
BR-03	Users must pay a non-refundable bid service fee before placing any bid.	FR-BID-01
BR-04	A user may place a maximum of	FR-BID-02

Rule ID	Business Rule	Related FRs
	150 bids per auction.	
BR-05	Winners must pay the winning bid amount within 24 hours (configurable) of auction closure.	FR-WIN-05
BR-06	If a winner fails to pay within the deadline, the next ranked winner is offered the opportunity.	FR-WIN-06
BR-07	An auction is extended by 24 hours if the minimum bid threshold is not met (fair-play).	FR-AUCT-04
BR-08	An auction is extended by 24 hours if no unique bids exist at closure time.	FR-AUCT-05
BR-09	An auction closes immediately when the maximum bid count is reached.	FR-AUCT-06
BR-10	Admins may force-close an auction without declaring a winner.	FR-AUCT-07
BR-11	Bid amounts are encrypted at rest after auction closure to protect strategic information.	FR-BID-06
BR-12	All monetary values are expressed in Ethiopian Birr (ETB) with 2 decimal places.	\$1.2
BR-13	Users must accept the current version of Terms & Conditions before bidding.	FR-TC-01
BR-14	Products must be in APPROVED status before they can be associated with an auction.	FR-PROD-02
BR-15	Settlement reports must account for total revenue, platform share, tax, and commission.	FR-ADM-08

1.15 12. Acceptance Criteria

Acceptance criteria define the verifiable conditions that must be met for each requirement to be considered satisfied. Each criterion is testable and measurable.

1.15.1 12.1 Authentication & Registration

Req ID	Acceptance Criteria
FR-AUTH-01	Given a valid phone, email, or OAuth credential, when the user submits registration, then an account is created and a verification challenge is initiated. All five strategies are tested end-to-end.
FR-AUTH-02	Given a password, when stored, then the stored value is a bcrypt hash with cost factor 12 and cannot be reversed to the plaintext.
FR-AUTH-03	Given valid credentials, when the user logs in, then a JWT access token (15-min expiry) and refresh token (7-day expiry) are issued. On refresh, a new refresh token is issued and the old one is invalidated.
FR-AUTH-05	Given 5 failed login attempts within 60 seconds, when a 6th attempt is made, then the request is rejected with HTTP 429.
FR-AUTH-09	Given 5 failed PIN attempts, when a 6th attempt is made, then the wallet is locked for 30 minutes.

1.15.2 12.2 Product & Auction Management

Req ID	Acceptance Criteria
FR-PROD-01	Given an admin with products:write permission, when CRUD operations are performed, then all operations succeed and are logged to the audit trail.
FR-PROD-02	Given a new product, when created, then its status is PENDING. Given admin approval, then status transitions to APPROVED and the action is audited. Given admin rejection, then status transitions to REJECTED with reason recorded. Given a PENDING or REJECTED product, when used for auction creation, then the operation is rejected.
FR-AUCT-04	Given an auction at closure with bids below minimum threshold, when closure is evaluated, then the auction end time is extended by 24 hours.
FR-TC-01	Given a user who has not accepted the current T&C version, when attempting to bid, then the bid is rejected and the user is prompted to accept T&C. Given acceptance, when the user bids, then the bid is accepted and the acceptance is recorded

Req ID	Acceptance Criteria
	with version, timestamp, and user ID.

1.15.3 12.3 Bidding Engine

Req ID	Acceptance Criteria
FR-BID-02	Given a user with 150 bids in an auction, when a 151st bid is attempted, then the request is rejected.
FR-BID-04	Given multiple bids with varying amounts, when the auction is queried for the lowest unique bid, then the correct lowest unique amount is returned via Redis ZSET computation.
FR-BID-07	Given the same nonce submitted twice within 60s, when the second request is received, then it is rejected as a replay.

1.15.4 12.4 Winner Determination & Payment

Req ID	Acceptance Criteria
FR-WIN-01	Given an auction with bids, when the auction closes, then the winner is correctly identified as the lowest unique bidder.
FR-WIN-06	Given a winner who has not paid within 24 hours, when the deadline expires, then the winner is marked expired and the next ranked winner is notified.
FR-WIN-10	Given a winner with a pending payment, when 6 hours and 1 hour remain before the deadline, then SMS and push notifications are sent and logged.

1.15.5 12.5 Admin Operations

Req ID	Acceptance Criteria
FR-ADM-08	Given a settlement period, when a report is generated, then it contains total revenue, platform share, tax withheld, and commission per auction, is exportable in CSV and PDF, and the generation is logged.
FR-ADM-09	Given the analytics dashboard, when accessed with a date range, then revenue, user, auction, bid, and payment analytics are displayed with correct aggregations.
FR-ADM-10	Given the audit log viewer, when filters are applied (actor, action, entity, date range), then matching logs are returned with pagination, sorting, and CSV export capability.
FR-ADM-11	Given the winner management dashboard, when an admin views winners by status, then winners are correctly filtered. When an admin extends a deadline or triggers rotation, then the action succeeds and is audited.

1.15.6 12.6 Performance & Caching

Req ID	Acceptance Criteria
FR-PERF-01	Given a read-heavy endpoint, when requested, then the response is served from Redis cache on cache hit. When the underlying data changes, then the cache is invalidated. When the cache is unavailable, then the system falls back to the database and returns correct results.
NFR-PERF-01	Given normal load conditions, when read API responses are measured at p95, then latency is $\leq 100\text{ms}$.

1.15.7 12.7 Security

Req ID	Acceptance Criteria
NFR-SEC-03	Given a webhook with an invalid HMAC-SHA256 signature, when received, then the request is rejected with HTTP 401 and logged.
NFR-SEC-08	Given an existing audit log entry, when an UPDATE or DELETE is attempted, then the operation is rejected at the database level.

1.16 13. Traceability Matrix

Each requirement is traced to its SDD section, test coverage, and implementation location. NFR entries are included for completeness.

Req ID	Requirement	Priority	SDD Section	Test Coverage	Implementation
FR-AUTH-01	Multi-strategy registration	Must	§3.1, §5.2	auth.e2e-spec	identity-service/src/auth/
FR-AUTH-02	bcrypt password hashing	Must	§7.1, §7.4	auth.service.spec	identity-service/src/auth/auth.service.ts
FR-AUTH-03	JWT + refresh tokens	Must	§3.1, §7.1	auth.e2e-spec	identity-service/src/auth/strategies/
FR-AUTH-04	Refresh token bcrypt hashing	Must	§7.1	auth.e2e-spec	identity-service/src/auth/auth.service.ts
FR-AUTH-05	Login rate limiting	Must	§4.4, §7.3	auth.service.spec	identity-service/src/auth/auth.service.ts
FR-AUTH-	Auto-refresh 60s before	Should	§3.1	api.ts	takelow-

Req ID	Requirement	Priority	SDD Section	Test Coverage	Implementation
06	expiry				web/src/api.ts
FR-AUTH-07	Invalidate sessions on ban	Must	§7.1	auth.e2e-spec	identity-service/src/auth/auth.service.ts
FR-AUTH-08	Wallet PIN setup	Must	§3.1, §7.1	wallet.e2e-spec	identity-service/src/wallet/
FR-AUTH-09	PIN lockout after 5 failures	Must	§3.1, §7.1	wallet.e2e-spec	identity-service/src/wallet-pin.service.ts
FR-PROD-01	Product CRUD	Must	§3.2	admin.e2e-spec	auction-engine/src/admin/auction-manage.controller.ts
FR-PROD-02	Product approval workflow	Must	§3.2, §11 (BR-14)	product-approval.e2e-spec	auction-engine/src/admin/product-approval.service.ts
FR-AUCT-01	Auction creation	Must	§3.2	admin.e2e-spec	auction-engine/src/admin/auction-manage.controller.ts
FR-AUCT-02	5-char public code	Must	§3.2	auction.entity.spec	database/migrations/031
FR-AUCT-03	Display active/closed auctions	Must	§3.2	auctions.e2e-spec	query-service/src/auctions/
FR-AUCT-04	Fair-play extension (min_bid)	Should	§3.2, §11 (BR-07)	auction-closure.e2e-spec	auction-engine/src/winner/auction-closure.service.ts
FR-AUCT-05	No-unique-bid extension	Should	§3.2, §11 (BR-08)	auction-closure.e2e-spec	auction-engine/src/winner/auction-closure.service.t

Req ID	Requirement	Priority	SDD Section	Test Coverage	Implementation
FR-AUCT-06	Max bid early closure	Must	§3.2, §11 (BR-09)	bidding.e2e-spec	s auction-engine/src/bidding/bidding.service.ts
FR-AUCT-07	Force-close by admin	Must	§3.2, §11 (BR-10)	admin.e2e-spec	auction-engine/src/admin/auction-manage.controller.ts
FR-BID-01	Bid fee requirement	Must	§3.3, §11 (BR-03)	bidding.e2e-spec	auction-engine/src/bidding/
FR-BID-02	Max 150 bids per user	Must	§3.3, §11 (BR-04)	bidding.e2e-spec	auction-engine/src/bidding/bidding.service.ts
FR-BID-03	Ticket number generation	Must	§3.3	bidding.e2e-spec	auction-engine/src/bidding/bidding.service.ts
FR-BID-04	LUB via Redis ZSETs	Must	§3.3, §4.1, §11 (BR-01/02)	winner.service.spec	auction-engine/src/winner/
FR-BID-05	Duplicate bid notification	Should	§3.3	bidding.e2e-spec	auction-engine/src/bidding/bidding.service.ts
FR-BID-06	AES-256-GCM encryption	Must	§3.3, §7.4, §11 (BR-11)	bidding.service.spec	auction-engine/src/common/bid-encryption.service.ts
FR-BID-07	Nonce validation	Must	§3.3	bidding.e2e-spec	auction-engine/src/common/nonce.guard.ts
FR-BID-08	Bidding window validation	Must	§3.3	bidding.e2e-spec	auction-engine/src/common/bidding-

Req ID	Requirement	Priority	SDD Section	Test Coverage	Implementation
					window.interceptor.ts
FR-BID-09	BullMQ batch persistence	Should	§3.3	worker.e2e-spec	auction-engine/src/worker/bullmq.worker.ts
FR-BID-10	Socket.io broadcast	Must	§3.3	gateway.e2e-spec	auction-engine/src/bidding/gateway/auction.gateway.ts
FR-TC-01	T&C acceptance before bidding	Must	§3.3, §9.3, §11 (BR-13)	terms.e2e-spec	identity-service/src/terms/
FR-WIN-01	Winner calculation	Must	§3.4, §11 (BR-01)	winner.e2e-spec	auction-engine/src/winner/winner.service.ts
FR-WIN-02	Multiple winners	Must	§3.4	winner.e2e-spec	auction-engine/src/winner/winner.service.ts
FR-WIN-03	Winner ranking	Must	§3.4	winner.e2e-spec	auction-engine/src/winner/winner.service.ts
FR-WIN-04	Multi-channel notifications	Must	§3.4	notifications.e2e-spec	identity-service/src/notifications/
FR-WIN-05	24h payment deadline	Must	§3.4, §11 (BR-05)	payment.e2e-spec	auction-engine/src/payment/payment.service.ts
FR-WIN-06	Winner rotation	Must	§3.4, §11 (BR-06)	payment.e2e-spec	auction-engine/src/payment/payment.service.ts
FR-WIN-07	Multiple payment methods	Must	§3.4	payment.e2e-spec	auction-engine/src/payment/

Req ID	Requirement	Priority	SDD Section	Test Coverage	Implementation
FR-WIN-08	Payment reconciliation cron	Must	§3.4, §8.2	payment.e2e-spec	auction-engine/src/payment/payment.service.ts
FR-WIN-09	Payment expiry (30s)	Must	§3.4	payment.e2e-spec	auction-engine/src/payment/payment.service.ts
FR-WIN-10	Payment reminder notifications	Must	§3.4, §9.3	payment-reminder.e2e-spec	auction-engine/src/payment/payment-reminder.service.ts
FR-WAL-01	Wallet balance/deposit/history	Must	§3.5	wallet.e2e-spec	identity-service/src/wallet/wallet.service.ts
FR-WAL-02	Atomic fee deduction	Must	§3.5	wallet.e2e-spec	identity-service/src/wallet/wallet.service.ts
FR-WAL-03	Wallet refunds	Must	§3.5	wallet.e2e-spec	identity-service/src/wallet/wallet.service.ts
FR-WAL-04	Fintech webhook deposit	Must	§3.5	wallet.e2e-spec	identity-service/src/wallet/wallet.service.ts
FR-NOT-01	In-app notifications	Must	§3.6	notifications.e2e-spec	identity-service/src/notifications/
FR-NOT-02	Push notifications (Expo)	Should	§3.6	notifications.e2e-spec	identity-service/src/notifications/notification.service.ts
FR-NOT-03	SMS notifications	Should	§3.6	notifications.e2e-spec	identity-service/src/notifications/notification.service.ts

Req ID	Requirement	Priority	SDD Section	Test Coverage	Implementation
FR-NOT-04	Bulk mark-read	Must	§3.6	notifications.e2e-spec	identity-service/src/notifications/notifications.controller.ts
FR-ADM-01	Admin dashboard stats	Must	§3.7	admin.e2e-spec	query-service/src/admin/
FR-ADM-02	User management	Must	§3.7	admin.e2e-spec	identity-service/src/admin/admin.controller.ts
FR-ADM-03	Fine-grained permissions	Must	§3.7	admin.e2e-spec	identity-service/src/admin/permissions.guard.ts
FR-ADM-04	Manual winner draw	Must	§3.7	admin.e2e-spec	auction-engine/src/admin/auction-manage.controller.ts
FR-ADM-05	Live auction monitor	Must	§3.7	admin.e2e-spec	auction-engine/src/admin/auction-manage.controller.ts
FR-ADM-06	Immutable audit trail	Must	§3.7, §7.5	audit.e2e-spec	identity-service/src/admin/audit.service.ts
FR-ADM-07	CSV export	Must	§3.7	admin.e2e-spec	identity-service/src/admin/admin.controller.ts
FR-ADM-08	Settlement reports	Must	§3.7, §8.2, §9.1	settlement.e2e-spec	query-service/src/admin/settlement.service.ts
FR-ADM-09	Advanced analytics dashboard	Must	§3.7	analytics.e2e-spec	query-service/src/admin/analytics.service.ts

Req ID	Requirement	Priority	SDD Section	Test Coverage	Implementation
FR-ADM-10	Audit log viewer + CSV export	Must	§3.7, §7.5	audit-viewer.e2e-spec	identity-service/src/admin/audit-viewer.controller.ts
FR-ADM-11	Winner management dashboard	Must	§3.7	winner-mgmt.e2e-spec	auction-engine/src/admin/winner-management.controller.ts
FR-FAV-01	Favorites CRUD	Should	§3.8	favorites.e2e-spec	query-service/src/favorites/
FR-FAV-02	Favorites watchlist	Should	§3.8	favorites.e2e-spec	query-service/src/favorites/
FR-AUD-01	Admin action audit logging	Must	§3.9, §7.5	audit.e2e-spec	identity-service/src/admin/audit.service.ts
FR-AUD-02	Bidding event audit logging	Must	§3.9	auction.e2e-spec	auction-engine/src/bidding/bidding.service.ts
FR-AUD-03	Payment event audit logging	Must	§3.9	payment.e2e-spec	auction-engine/src/payment/payment.controller.ts
FR-AUD-04	User data access audit logging	Must	§3.9	query.e2e-spec	query-service/src/auctions/auctions.service.ts
FR-AUD-05	Audit log query API	Must	§3.9	audit.e2e-spec	identity-service/src/admin/audit.service.ts
FR-AUD-06	Audit log storage	Must	§3.9, §6.1	schema review	database/migrations/024
FR-REDIS-01	Redis Sentinel support	Should	§3.10, §4.2	redis.e2e-spec	auction-engine/src/common/redis.provider

Req ID	Requirement	Priority	SDD Section	Test Coverage	Implementation
FR-REDIS-02	Redis Cluster support	Should	§3.10, §4.2	redis.e2e-spec	er.ts auction-engine/src/common/redis.provider.ts
FR-REDIS-03	Auto-detect Redis HA config	Should	§3.10	config review	identity-service/src/config/redis.config.ts
FR-REDIS-04	Standalone Redis backward compat	Must	§3.10	dev review	auction-engine/src/common/redis.provider.ts
FR-BACKUP-01	pgBackRest backups	Must	§3.11	backup.sh	scripts/backup-pgbackrest.sh
FR-BACKUP-02	WAL-G cloud backups	Should	§3.11	backup.sh	scripts/backup-walg.sh
FR-BACKUP-03	PITR support	Must	§3.11, §8.4	restore.sh	scripts/restore-disaster-recovery.sh
FR-BACKUP-04	RTO/RPO targets	Must	§3.11, §8.4	DR test	docs/SRS.md §8.4
FR-BACKUP-05	Automated restore scripts	Must	§3.11	restore.sh	scripts/restore-disaster-recovery.sh
FR-BACKUP-06	K8s backup CronJobs	Must	§3.11	k8s review	k8s/backup-cronjob.yaml
FR-WS-01	Socket.io Redis adapter	Must	§3.12, §4.2	gateway.e2e-spec	auction-engine/src/bidding/gateway/auction.gateway.ts
FR-WS-02	Cross-instance WS broadcast	Must	§3.12	gateway.e2e-spec	auction-engine/src/bidding/gateway/auction.gateway.ts
FR-WS-	Zero-code replica	Should	§3.12	k8s review	k8s/deployments

Req ID	Requirement	Priority	SDD Section	Test Coverage	Implementation
03	scaling				.yaml
FR-PERF-01	Redis caching layer	Must	§3.13, §4.1	cache.e2e-spec	query-service/src/common/cache.service.ts
NFR-PERF-01	Read API $\leq$ 100ms p95	Must	§4.1	load-tests/	All services
NFR-PERF-02	10K concurrent auctions	Must	§4.1	load-tests/	auction-engine/
NFR-PERF-03	Bid placement $\leq$ 200ms p95	Must	§4.1	load-tests/	auction-engine/src/bidding/
NFR-PERF-04	1,000 bids/s/auction	Must	§4.1	load-tests/	auction-engine/src/bidding/
NFR-PERF-05	WS updates $\leq$ 50ms	Must	§4.1	load-tests/	auction-engine/src/bidding/gateway/
NFR-PERF-06	Indexed queries only	Must	§4.1	query review	database/migrations/
NFR-SCALE-01	Citus horizontal scaling	Must	§4.2	k8s review	k8s/deployments.yaml
NFR-SCALE-02	Read replicas	Should	§4.2	config review	query-service/src/config/
NFR-SCALE-03	HPA support	Should	§4.2	k8s review	k8s/hpa.yaml
NFR-SCALE-04	Redis clustering	Should	§4.2	k8s review	redis-cluster.conf
NFR-SCALE-05	WS horizontal scaling	Must	§4.2	load-tests/	auction-engine/src/bidding/gateway/
NFR-	Sentinel	Should	§4.2	DR test	redis-

Req ID	Requirement	Priority	SDD Section	Test Coverage	Implementation
SCALE-06	failover < 30s				sentinel.conf
NFR-SCALE-07	Redis Cluster sharding	Should	§4.2	k8s review	redis-cluster.conf
NFR-AVAIL-01	99.9% uptime target	Must	§4.3	monitoring	All services
NFR-AVAIL-02	Health endpoints return 503	Must	§4.3	health.e2e-spec	All services health controllers
NFR-AVAIL-03	K8s liveness/readiness probes	Must	§4.3	k8s review	k8s/deployments .yaml
NFR-AVAIL-04	Quarterly DR testing	Must	§4.3	DR test	scripts/restore-disaster-recovery.sh
NFR-AVAIL-05	Monthly PITR verification	Must	§4.3	DR test	scripts/restore-disaster-recovery.sh
NFR-AVAIL-06	Staging failover testing	Must	§4.3	staging DR test	docs/REDIS_HA.md
NFR-SEC-01	CORS protection	Must	§4.4	security review	All services main.ts
NFR-SEC-02	JWT secret validation	Must	§4.4	startup test	All services config
NFR-SEC-03	HMAC-SHA256 webhook verification	Must	§4.4	webhook.e2e-spec	identity-service/src/wallet/
NFR-SEC-04	Nonce replay prevention	Must	§4.4	nonce.e2e-spec	auction-engine/src/common/nonce.guard.ts
NFR-SEC-05	Internal API key auth	Must	§4.4	internal-api.e2e-spec	All services internal guards
NFR-SEC-06	Sensitive field hashing	Must	§4.4	security review	identity-service/src/auth/

Req ID	Requirement	Priority	SDD Section	Test Coverage	Implementation
NFR-SEC-07	5xx error masking	Must	\$4.4	error-handling.e2e-spec	All services exception filters
NFR-SEC-08	Immutable audit logs	Must	\$4.4	schema review	database/migrations/024
NFR-SEC-09	Redis HA auth + TLS	Must	\$4.4	k8s review	redis.conf
NFR-SEC-10	Backup encryption at rest	Must	\$4.4	backup review	backup-pgbackrest.sh
NFR-REL-01	Idempotent migrations	Must	\$4.5	migration test	database/migrations/
NFR-REL-02	Payment gateway retry	Must	\$4.5	payment.e2e-spec	auction-engine/src/payment/
NFR-REL-03	BullMQ retry with backoff	Must	\$4.5	worker.e2e-spec	auction-engine/src/worker/
NFR-REL-04	Referential integrity	Must	\$4.5	schema review	database/migrations/
NFR-MAIN-01	TypeScript strict mode	Must	\$4.6	tsc -noEmit	All projects
NFR-MAIN-02	Explicit migrations only	Must	\$4.6	config review	Prisma config
NFR-MAIN-03	NestJS module architecture	Must	\$4.6	code review	All backend services
NFR-MAIN-04	Component-based frontend	Must	\$4.6	code review	takelow-web/, takelow-app/
NFR-USAB-01	Offline cached viewing	Should	\$4.7	mobile test	takelow-app/
NFR-USAB-02	Responsive web	Must	\$4.7	responsive test	takelow-web/
NFR-	Payment	Must	\$4.7	payment.e2e-	takelow-web/,

Req ID	Requirement	Priority	SDD Section	Test Coverage	Implementation
USAB-03	status indicators			spec	takelow-app/

1.17 14. Glossary

Term	Definition
AES-256-GCM	Advanced Encryption Standard with 256-bit keys in Galois/Counter Mode; provides authenticated encryption used for bid amount encryption at rest.
Audit Trail	An immutable, append-only record of system events used for compliance, dispute resolution, and forensic analysis.
Availability	The proportion of time a system is operational and accessible; expressed as a percentage (e.g., 99.9%).
bcrypt	A password hashing function designed to be computationally expensive, resistant to brute-force and rainbow-table attacks.
BullMQ	A Redis-based message queue library for Node.js used for asynchronous job processing and batch persistence.
Cache-Aside Pattern	A caching strategy where the application checks the cache first; on miss, it queries the database and populates the cache.
Citus	A PostgreSQL extension that distributes data across multiple nodes for horizontal scaling.
CORS	Cross-Origin Resource Sharing; a browser security mechanism that restricts cross-origin HTTP requests.
CSV	Comma-Separated Values; a text format for tabular data export.
DTO	Data Transfer Object; a typed object used to validate and structure data at API boundaries.
ETB	Ethiopian Birr; the official currency of Ethiopia, used for all monetary values in the system.
Expo	A framework and platform for building React Native mobile applications.
Expo Push Service	A hosted service for sending push notifications to Expo-based mobile applications.
Fair-Play Extension	An auction duration extension triggered when minimum participation thresholds are not met, ensuring adequate competition.

Term	Definition
HMAC	Hash-based Message Authentication Code; used to verify the integrity and authenticity of webhook payloads.
HPA	Horizontal Pod Autoscaler; a Kubernetes feature that automatically scales the number of pods based on observed metrics.
IEEE-830	IEEE Standard 830-1998: IEEE Recommended Practice for Software Requirements Specifications.
ISO/IEC 27001	International standard for information security management systems.
JWT	JSON Web Token; a compact, self-contained token format used for stateless authentication.
K8s	Kubernetes; a container orchestration platform used for production deployment.
LUB	Lowest Unique Bid; the auction mechanism where the winner is the participant who submitted the lowest bid amount that no other participant also submitted.
Must	A mandatory requirement per the priority convention; its absence blocks acceptance.
NIST SP 800-53	A NIST publication providing a catalog of security and privacy controls for federal information systems.
Nonce	A single-use cryptographic value used to prevent replay attacks on bid submissions.
NFR	Non-Functional Requirement; a requirement describing system qualities such as performance, security, and reliability.
OAuth 2.0	An authorization framework enabling third-party login (e.g., TeleBirr, Banking API).
OTP	One-Time Password; a single-use code used for phone number verification.
OWASP Top 10	A standard awareness document for the top 10 web application security risks, published by OWASP.
PITR	Point-in-Time Recovery; the ability to restore a database to a specific moment in time using WAL archives.
PIN	Personal Identification Number; a 4-6 digit numeric code used for wallet authentication.
Prisma	A type-safe ORM for Node.js and TypeScript, used for database access and migration management.
Pub/Sub	Publish-Subscribe; a messaging pattern where publishers

Term	Definition
	send messages without knowledge of subscribers, used via Redis.
RPO	Recovery Point Objective; the maximum acceptable data loss measured in time.
RTO	Recovery Time Objective; the maximum acceptable time to restore system operation after a failure.
Should	A recommended requirement per the priority convention; its absence is a non-blocking defect.
Socket.io	A WebSocket library enabling real-time bidirectional communication between client and server.
SSRF	Server-Side Request Forgery; an attack where an attacker induces the server to make unauthorized requests.
TLS	Transport Layer Security; a cryptographic protocol providing secure communication over a network.
T&C	Terms & Conditions; the legal agreement users must accept before participating in auctions.
WAL	Write-Ahead Log; a PostgreSQL mechanism for durability and point-in-time recovery.
WAL-G	A tool for continuous PostgreSQL backup and restoration using WAL archiving to cloud storage.
ZSET	Sorted Set; a Redis data structure that maintains elements in sorted order by score, used for bid frequency tracking.

End of SRS v6.0